

PASO 2

INTEGRA

Infraestructura de Trazabilidad e Identidad para la Gestión de Recursos de Asignación

Arquitectura Técnica

Solución Blockchain + Ciberseguridad + IoT

Propuesta de implementación: Argentina — Modelo replicable para América Latina

Plataforma: ledger propio, con arquitectura de identidad y canales inspirada en Hyperledger Fabric · Estándar IoT: MQTT/TLS ·

Identidad: PKI X.509 (RSA-2048)

Nota de alcance: este documento describe tanto la arquitectura objetivo (la que fundamenta las decisiones de diseño) como el estado real del prototipo implementado. Donde ambas difieren, se indica explícitamente cuál es cuál — ver DECISIONES_DE_ALCANCE.md para el detalle completo de cada decisión de alcance.

1. Introducción y Objetivos de la Arquitectura

INTEGRA es la infraestructura técnica diseñada para responder con precisión al mapa de amenazas identificado en el Paso 1. La propuesta toma a Argentina — con la coordinadora nacional de trasplantes como organismo rector hipotético de referencia — como primer caso de implementación, pero cada decisión arquitectónica fue tomada pensando en la replicabilidad para otros países de Latinoamérica.

La arquitectura de INTEGRA se construye desde adentro del flujo de información, con seguridad por diseño (Security by Design) como restricción fundacional. Cada componente tiene un origen explícito en una amenaza documentada y responde a ella con precisión técnica.

1.1 Principios rectores del diseño

- **Security by Design:** la seguridad no es un módulo adicional, es una restricción de arquitectura desde el inicio
- **Zero Trust:** ningún actor, nodo ni dispositivo es confiable por defecto. Toda acción requiere verificación
- **Inmutabilidad como control:** el registro blockchain reemplaza la auditoría manual como mecanismo de accountability
- **Resiliencia operativa:** continuidad durante ataques en ventanas críticas de isquemia
- **Interoperabilidad controlada:** integración con sistemas legados sin ampliar la superficie de ataque
- **Mínimo privilegio:** cada rol accede únicamente a los datos y funciones estrictamente necesarios
- **Replicabilidad regional:** la arquitectura es parametrizable para adaptarse al marco institucional de cada país

2. Selección y Justificación del Modelo de Plataforma

El modelo de identidad, canales y consenso de Hyperledger Fabric se tomó como arquitectura de referencia porque resuelve directamente los vectores de amenaza identificados en el Paso 1: PKI nativa por organización, canales privados, y un modelo de red permissionada pensado para consorcios institucionales — exactamente el escenario de coordinadora nacional/hospitales/auditores que describe este proyecto.

Decisión de alcance: para esta fase del prototipo, INTEGRA implementa un ledger propio que reproduce ese modelo de identidad, canales y quorum, sin depender del runtime real de Hyperledger Fabric. La comparativa de esta sección fundamenta esa elección de diseño como arquitectura objetivo para una fase de producción institucional; no describe el motor que corre hoy. Detalle completo en DECISIONES_DE_ALCANCE.md.

2.1 Análisis comparativo de plataformas (arquitectura de referencia)

Criterio	Hyperledger Fabric	Ethereum (privado)	Quorum (JP Morgan)	Corda (R3)
Tipo de red	Permissionada ✓	Permissionada/pública	Permissionada	Permissionada
Control de identidad	PKI nativa + MSP por org ✓	Claves privadas, sin MSP	PKI + TLS mutual	X.509 por nodo
Confidencialidad	Canales privados por org ✓	Transacciones visibles X	Transacciones privadas (Tessera)	Solo entre partes involucradas
Rendimiento (TPS)	~3.000–10.000 TPS ✓	~100–300 TPS X	~500–1.500 TPS	~500 TPS
Integración médica	APIs REST + SDKs ✓	Web3.js / RPC	APIs REST	SDKs propietarios
Madurez en salud pública	Alta — antecedentes en salud pública internacional ✓	Baja en sector público X	Media — sector financiero	Media — sector financiero

2.2 Justificación por amenaza neutralizada — mecanismo real del prototipo

Amenaza (Paso 1)	Capacidad del modelo	Mecanismo técnico implementado
Insider manipula lista de espera (CRÍTICO)	Registro inmutable: cada transacción es irreversible y firmada digitalmente	Ledger append-only con hash-encadenado + política de endorsement obligatoria (2+ organizaciones)
Suplantación de identidad (Spoofing)	Identidad por organización: cada actor tiene certificado X.509 propio y verificable	PKI propia con CA por institución (RSA-2048)
Repudio de acciones	Toda transacción lleva firma criptográfica del actor. No repudiable por diseño.	Firma RSA-2048 en cada bloque. Timestamp verificable.
Exposición de datos clínicos	Canales privados: datos HLA solo visibles para partes autorizadas	Aislamiento por canal/proyección de lectura. Datos cifrados at-rest.
Ransomware / DoS	Red distribuida: ningún nodo único concentra el riesgo de escritura	Quorum de replicación (3 de 4 nodos) + orderer único de Fase 1 (ver 2.3) + nodos peer redundantes
Escalada de privilegios	RBAC nativo: roles definidos por atributos del certificado	Control de acceso por rol asociado al certificado de organización

2.3 Consenso y ordenamiento — estado real vs. objetivo

El mecanismo de consenso implementado hoy es un quorum de replicación (3 de 4 nodos deben confirmar un bloque para darlo por válido) combinado con un orderer único en coordinador nacional, que es quien decide la secuencia global de bloques para evitar forks por escritura simultánea de varios nodos.

Decisión de alcance: el orderer único de hoy es la Fase 1 del piloto, análogo a un líder fijo en un esquema de consenso tipo Raft, con elección dinámica de líder planificada para fases posteriores — coherente con la arquitectura objetivo de esta sección. No es un servicio de ordenamiento Raft real todavía. El umbral de quorum se fijó en 3 de 4 (no en 2 de 4) de forma deliberada: con una red de 4 nodos, un umbral de 2 permitiría que dos mitades de la red se reconozcan como mayoría sin comunicarse entre sí.

3. Arquitectura de Identidad Criptográfica

La identidad criptográfica es el fundamento de toda la arquitectura INTEGRA. En el piloto argentino, la PKI se ancla a la coordinadora nacional de trasplantes como autoridad raíz. En la expansión regional, cada país incorpora su propia CA raíz bajo un modelo de confianza federado.

3.1 Actores del sistema e identidad

Los cuatro nodos operativos del prototipo actual están marcados como "(nodo activo)". El dispositivo IoT es un actor real pero no una organización ni un nodo propio. "Médico trasplantador" y "Sistema legado" son roles del diseño conceptual, no implementados hoy.

Actor	Tipo de identidad	Mecanismo de autenticación	Nivel de acceso (RBAC)
Coordinador nacional (nodo activo, puerto 3001)	Certificado X.509 institucional	Certificado de organización. Rol de orderer de Fase 1.	Endorsement de waiting-list, assignment y reception. Lectura total.
Coordinador provincial (nodo activo, puerto 3002)	Certificado X.509 institucional	Certificado de organización.	Puede actuar como la "organización distinta" que exige el endorsement de waiting-list. Lectura de proyección clínica.
Hospital donante (nodo activo, puerto 3003)	Certificado de organización (Org CA)	Certificado de organización.	Único firmante de donor-registry. Endorsement de assignment y custody.
Hospital receptor (nodo activo, puerto 3004)	Certificado de organización (Org CA)	Certificado de organización.	Endorsement de reception junto al coordinador nacional.
Dispositivo IoT (iot:sensor-...)	Certificado de dispositivo (IoT CA, TTL 72h)	TLS mutuo + certificado de dispositivo.	Solo escritura de telemetría (custody), junto a un hospital. No es una organización ni tiene nodo propio.
Médico trasplantador (rol conceptual, no implementado)	Certificado X.509 personal (CA hospitalaria)	MFA: biometría + PIN + certificado (diseño, no construido)	Diseño de referencia. Hoy no existe como actor separado del hospital que lo emplea.
Sistema legado / HIS-EMR (rol conceptual, no implementado)	Certificado de servicio (API Gateway)	OAuth 2.0 + mTLS (diseño, no construido)	Diseño de referencia para integración con sistemas hospitalarios existentes.
Organización candidata (diseñado, no implementado)	CSR sin clave privada	No existe transacción org-join en el código hoy.	N/A — ver Sección 3.3.

3.2 Infraestructura de clave pública (PKI) — jerarquía real del prototipo

- **Root CA de la red:** "INTEGRA Root CA", con una vigencia de 10 años. Es la raíz de confianza de las cuatro organizaciones del piloto. En la expansión regional, cada país incorporaría su propia Root CA bajo un modelo de confianza federado.

- **CA intermedia por organización:** cada una de las cuatro organizaciones tiene su propia CA intermedia, con vigencia de 5 años, y emite certificados hoja de 365 días para sí misma. Permite revocación localizada sin afectar a toda la red.
- **CA de dispositivos IoT:** CA intermedia específica para el ciclo de vida de certificados de sensores, con un certificado de hoja para el dispositivo simulado (iot:sensor-contenedor-001) con TTL de 72 horas.
- **Organizaciones registradas hoy:** la lista de organizaciones está fijada en el script de génesis de la CA (ca/generate-ca-hierarchy.js): coordinador-nacional, coordinador-provincial, hospital-donante, hospital-receptor. No hay un mecanismo para agregar una organización a esta lista sin modificar y volver a ejecutar ese script.
- **Algoritmo criptográfico:** RSA-2048 para firmas de actores, organizaciones y dispositivos IoT — decisión de alcance documentada en DECISIONES_DE_ALCANCE.md (no ECDSA P-256).

3.3 Onboarding de nuevas organizaciones — transacción org-join (propuesta de diseño)

Propuesta de diseño para cuando se implemente:

La organización candidata genera su propio CSR fuera de la red. La clave privada nunca sale de su infraestructura. El CSR se envía como transacción org-join, en estado pendiente.

Requiere endorsement de coordinador-nacional + otra organización activa — mismo patrón N-de-M que waiting-list.

La CA (nunca los nodos clínicos ni el dashboard) valida el CSR: algoritmo y longitud de clave, y que el CN no colisione con una organización existente.

El resultado —alta o rechazo— queda registrado de forma inmutable en el ledger.

4. Contratos del Prototipo (equivalentes a chaincode) y Lógica de Negocio

No hay un runtime de Hyperledger Fabric real desplegando chaincode independiente: la lógica de negocio vive en el módulo de endorsement del ledger propio (nodes/lib/endorsement.js) y sus reglas asociadas. El término

"chaincode" se usa acá para referirse a esa lógica por analogía funcional, no a módulos desplegados por separado.

Hay cinco tipos de transacción que producen un bloque, más un motor de consulta que no produce bloques.

Módulo (txType)	Función real	Amenaza neutralizada (Paso 1)
DonorRegistry (donor-registry)	Alta del donante: identidad, grupo sanguíneo, datos HLA, consentimiento. Firma únicamente válida si es de hospital-donante — cualquier otro actor es rechazado.	Spoofing de identidad de donante. Falsificación de datos de compatibilidad.
WaitingListManager (waiting-list)	Alta o cambio de un paciente en la lista de espera. Requiere coordinador-nacional + al menos otra organización distinta. Ningún actor solo puede decidir.	Insider manipula lista de espera (Prioridad #2). Repudio de modificaciones.
AssignmentContract (assignment)	Asigna un órgano. Requiere coordinador-nacional + hospital-donante, y exige que el timestamp de compatibilidad (emitido por CompatibilityEngine) tenga menos de 30 minutos — rechaza asignaciones sobre datos de compatibilidad vencidos.	Repudio de asignaciones. Uso de datos de compatibilidad obsoletos o manipulados.
CustodyChain (custody)	Registra la telemetría del contenedor durante el traslado. Firma el dispositivo IoT junto a un hospital. Solo acepta lecturas si el organId corresponde a un donante ya asignado; se corta al llegar la recepción.	Manipulación de tiempo de isquemia. Falsificación de cadena de custodia.
Reception (reception)	Cierra el circuito del trasplante: requiere hospital-receptor + coordinador-nacional. Impide que un mismo órgano se reciba dos veces.	Alteración retroactiva de registros de cierre. Doble conteo de un mismo órgano.
CompatibilityEngine (solo consulta, no produce bloque)	Endpoint de consulta (POST /compatibility/query) que calcula el ranking de compatibilidad por grupo sanguíneo y HLA (loci A, B, DR), y emite el timestamp de frescura que luego valida AssignmentContract.	Falsificación de compatibilidad HLA (Prioridad #3), en conjunto con la verificación de frescura del timestamp.

4.1 Políticas de endorsement (verificadas contra el código)

- **donor-registry:** firma únicamente de hospital-donante. Cualquier otro actor es rechazado.
- **waiting-list:** coordinador-nacional + al menos una organización distinta. Un actor solo, o un dispositivo IoT, no alcanza.
- **assignment:** coordinador-nacional + hospital-donante, con el timestamp de compatibilidad de CompatibilityEngine fresco (≤ 30 minutos). Un hospital solo, un médico, o un timestamp vencido, se rechazan.
- **custody:** el dispositivo IoT correspondiente + un hospital. Un IoT solo, o una organización sin sensor asociado, se rechazan.
- **reception:** hospital-receptor + coordinador-nacional. Cualquier otro par de firmantes se rechaza.
- **Quorum de red (independiente del endorsement):** 3 de 4 nodos deben confirmar la replicación de cualquier bloque, sin importar su txType, para darlo por persistido (ver Sección 2.3).

5. Integración IoT — Cadena de Custodia en Tiempo Real

El IoT en INTEGRA opera como evidencia forense en tiempo real. Los sensores en los contenedores de transporte generan un registro criptográfico de cada momento del traslado, eliminando la dependencia de reportes manuales susceptibles de alteración.

En el prototipo actual hay un único dispositivo simulado (iot:sensor-contenedor-001), no un subsistema de múltiples sensores. Simula una cadencia real de 1 lectura cada 5 segundos, con un tope de 80 lecturas (~6 minutos 40 segundos de viaje simulado) y una falla de temperatura programada a mitad de trayecto (~5,2°C, fuera del rango 0–4°C) para poder demostrar la detección de alerta. Para que la demo no dependa de esperar el reloj real, el envío efectivo al nodo se comprime a un intervalo de 80 ms entre lecturas, aunque el timestamp de cada una sigue avanzando de a 5 segundos simulados. El simulador no arranca con el resto de la red (corre en un perfil de Docker aparte); solo empieza a escribir después de un assignment válido, y se detiene al registrarse la reception.

5.1 Especificaciones de seguridad IoT

Control	Implementación técnica	Amenaza neutralizada
Autenticación de dispositivo	Certificado X.509 por dispositivo, emitido por CA IoT. TLS mutuo obligatorio.	Inyección de datos falsos desde dispositivos no autorizados.
Cifrado de telemetría	TLS 1.3 en tránsito. Cifrado en reposo en el gateway. Clave derivada del certificado.	Intercepción de comunicaciones IoT. Exposición de ruta de traslado.
Firma de datos en el edge	Cada lectura de sensor firmada con RSA-2048 antes de transmisión.	Tampering de datos de isquemia o temperatura durante el tránsito.
Rotación de credenciales	Certificados con TTL de 72h. Renovación automática vía protocolo EST.	Compromiso de credenciales IoT a largo plazo.
Alertas automáticas	Umbral en chaincode: temperatura fuera de rango, GPS sin señal, desvío de ruta, isquemia en límite.	Manipulación de cadena de frío. Desvío físico del traslado.
Operación offline	Gateway almacena hasta 24h de telemetría firmada. Transmite con evidencia de gap temporal al recuperar señal.	Pérdida de conectividad en zonas rurales.

5.2 Umbrales de alerta por tipo de órgano (diseño de referencia)

Órgano	Temperatura óptima	Isquemia máxima	Alerta crítica en blockchain
Corazón	0°C a 4°C	4–6 horas	A las 3h. Temperatura >4°C por más de 5 minutos.
Pulmón	0°C a 4°C	6–8 horas	A las 4h. Temperatura fuera de rango.
Hígado	0°C a 4°C	12–24 horas	A las 10h. Temperatura >5°C.
Riñón (caso piloto)	0°C a 4°C	24–36 horas	A las 20h. Temperatura fuera de rango sostenida.
Páncreas	0°C a 4°C	12–18 horas	A las 10h. Alerta de temperatura inmediata.

El riñón es el órgano seleccionado para el caso demostrativo del prototipo, por su mayor ventana de isquemia — facilita el testing sin presión de tiempo extrema.

6. Capas de Ciberseguridad por Nodo del Proceso — Arquitectura Objetivo

Nota de alcance: esta sección describe los controles de la arquitectura objetivo (SIEM, WAF, PAM, EDR). El prototipo actual implementa y valida el modelo de amenazas mediante una suite de 20 tests de seguridad automatizados (npm run test:seguridad), organizados en 8 bloques: Identidad y PKI (4), Registro de donantes (2), Endorsement (3), IoT y custodia (3), RBAC (3), Resiliencia (2), Trazabilidad (2) y Quorum (1). Dos de esos 20 (resiliencia ante caída de nodo, y quorum con peers caídos) requieren Docker y se saltan si la verificación corre solo en el host. No despliega todavía la infraestructura perimetral completa (SIEM/WAF/PAM como productos separados), que corresponde a una fase de hardening posterior sobre infraestructura institucional real. Existe además una suite aparte de 5 tests de endpoints del dashboard, que no forma parte de este conteo de seguridad.

Nodo	Riesgo (P1)	Controles de la arquitectura objetivo	Amenaza neutralizada
Hospital donante	CRÍTICO	MFA obligatorio (certificado + TOTP). Segmentación de red. Cifrado del transporte clínico. EDR en terminales.	Phishing, acceso físico, comunicación clínica en texto plano.
la coordinadora nacional de trasplantes (coordinación)	CRÍTICO	Mínimo privilegio estricto. PAM con grabación de sesiones. SIEM con alertas. Backup inmutable del ledger offline.	Insider malicioso, escalada de privilegios, movimiento lateral.
Sistema de asignación	CRÍTICO	Reglas de compatibilidad como chaincode inmutable. API Gateway con WAF. Rate limiting por actor.	Inyección en portales legacy, manipulación de parámetros.
Traslado del órgano	ALTO	Comunicaciones IoT cifradas TLS 1.3 con autenticación mutua. Datos de ruta solo visibles en canal privado.	Intercepción de ruta, compromiso de sensores IoT.
Hospital receptor	ALTO	Verificación criptográfica de la cadena de custodia antes de aceptar. MFA para confirmación de recepción.	Aceptación con documentación falsificada, sistemas legacy vulnerables.

7. Modelo de Gobernanza y Control de Acceso (RBAC)

7.1 Canales de comunicación (arquitectura objetivo)

Nota de alcance: el ledger propio del prototipo no implementa canales al estilo Fabric (espacios de datos cifrados y aislados por subconjunto de organizaciones). El aislamiento real hoy se logra por endpoint y por identidad: cada nodo expone su propio ledger crudo, y una proyección de lectura filtrada por rol — no por una segmentación criptográfica de canales. Lo que sigue es el diseño objetivo para una fase con Hyperledger Fabric real.

- **Canal principal (objetivo):** accesible por todas las organizaciones. Asignaciones, custodia, cierre del circuito. Datos anonimizados de donante.
- **Canal clínico (objetivo):** solo el hospital donante, la coordinadora nacional y el hospital receptor del caso específico. Datos clínicos sensibles y compatibilidad HLA.
- **Canal de auditoría (objetivo):** pensado para auditores con certificado de solo lectura. Hoy no hay un rol de auditor vigente en el sistema; este canal queda como diseño a construir junto con ese rol.

7.2 Matriz de roles y permisos — estado real del prototipo

Rol	donor-registry	waiting-list	assignment	custody	reception
Coordinador nacional	No firma	Endorsement	Endorsement	No	Endorsement
Coordinador provincial	No firma	Puede ser la "otra org"	No	No	No
Hospital donante	Único firmante	No	Endorsement	Endorsement (si tiene el sensor)	No
Hospital receptor	No firma	No	No	No	Endorsement
Dispositivo IoT	No	No	No	Endorsement (junto a un hospital)	No

Lectura: GET /ledger devuelve el ledger crudo, solo al propio nodo (identidad por header x-actor = nombre de la organización). GET /dashboard/casos/* y /overview (proyección clínica) son accesibles al propio nodo, o a coordinador-nacional/provincial. GET /health, /dashboard/health y /verify-integrity son públicos. El dashboard no escribe en ningún caso — es de solo lectura, coherente con la decisión de alcance ya documentada.

Limitación real de la interfaz: la vista del dashboard está fija a coordinador-nacional; el cambio de rol en la UI (setRole) está desactivado en esta versión. Cualquier mención a "cambiar de rol y ver datos distintos" en otros materiales del proyecto debe verificarse contra el estado actual del dashboard antes de mostrarse en una demo en vivo.

8. Trazabilidad Amenaza → Control Técnico

La siguiente tabla cierra el ciclo entre el análisis de amenazas del Paso 1 y la arquitectura INTEGRA, con el mecanismo real del prototipo — no una referencia genérica a la plataforma objetivo.

Prior	Amenaza (Paso 1)	Score	Control INTEGRA (implementación real)	Componente
#1	Ransomware durante coordinación activa	9.8	Quorum de replicación (3 de 4 nodos) + orderer único de Fase 1 + IRP + backup offline.	Ledger propio + orderer + IRP
#2	Insider manipula lista de espera	9.8	WaitingListManager: endorsement de múltiples organizaciones + firma digital inmutable.	Chaincode + Endorsement Policy

Prior	Amenaza (Paso 1)	Score	Control INTEGRA (implementación real)	Componente
#3	Falsificación de compatibilidad HLA	9.5	CompatibilityEngine inmutable. DonorRegistry con firma del hospital.	Chaincode + PKI + Canal clínico
#4	Ausencia de MFA en acceso crítico	9.5	MFA obligatorio: certificado X.509 (RSA-2048) + TOTP. TTL corto para IoT.	PKI + MFA
#5	Comunicación clínica sin cifrado	9.2	TLS 1.3 obligatorio para las comunicaciones entre nodos y con dispositivos.	TLS 1.3
#6	IoT sin autenticación	8.1	Certificado X.509 por dispositivo. TLS mutuo. Firma RSA-2048 en edge. Rotación cada 72h.	CA IoT + MQTT/TLS + Firma en edge
#7	IT tercerizado sin control	8.4	Acceso cero por defecto para proveedores. PAM con grabación de sesiones (arquitectura objetivo).	PAM + RBAC cero-confianza
#8	Sistemas legacy sin soporte	7.6	Aislamiento de red sin acceso al ledger. Integración solo vía API Gateway con validación.	API Gateway + Segmentación
#9	Admisión no autorizada / suplantación organizacional en onboarding	9.0 (estimado)	Propuesta de diseño (no implementada): CSR sin clave privada + endorsement N-de-M + validación de CN único por la CA + registro inmutable de altas y rechazos.	OrgRegistry (diseñado, no construido) + CA + Endorsement Policy

Nota técnica: la arquitectura implementada corresponde a un ledger propio (no Hyperledger Fabric real), con firmas RSA-2048 (no ECDSA P-256) y un modelo de consenso por quorum de replicación (constante fija QUORUM_NODOS = 3, no recalculada dinámicamente) con orderer único de Fase 1 (no un servicio Raft real). Los canales de aislamiento de datos (Sección 7.1) son diseño objetivo, no implementados. El rol de auditor externo es código residual, no un rol vigente. La transacción de onboarding de organizaciones (org-join / OrgRegistry) es una propuesta de diseño, no código implementado. Estas son decisiones y limitaciones de alcance documentadas en DECISIONES_DE_ALCANCE.md, tomadas por restricciones de tiempo del prototipo — la arquitectura objetivo sigue siendo Hyperledger Fabric con ordering service Raft para una fase de producción institucional. TLS 1.3 sí corresponde a la versión realmente utilizada. La arquitectura es parametrizable para su adaptación regional.